

Abdul Wahid

EC-Council CND (Certified Network Defender)

Attack Surface Analysis & Threat Assessment – Windows Attack Surface Analyzer & OWASP ZAP Attack Surface Detector

Executive Summary

Every open door is an invitation. Attack surface analysis shows you exactly which doors exist — and which ones you just opened.

Module 19 trains defenders to map and measure the attack surface before adversaries exploit it. On a Windows 10 target (192.168.100.129), Microsoft Attack Surface Analyzer is installed and used to capture a clean baseline snapshot. Port 21 (FTP) is then deliberately enabled, expanding the surface. A second scan is run and the two snapshots are compared, instantly revealing the new open port and demonstrating how configuration changes increase risk.

The analysis then moves to the application layer. OWASP ZAP is launched, the Attack Surface Detector add-on is installed, source code is imported, and the tool maps every reachable endpoint, parameter, and entry point of the web application — turning invisible attack paths into a clear, reviewable inventory.

Result: complete, practical mastery of both operating-system and web-application attack surface analysis — the foundational skill for reducing exposure and performing effective threat assessment.

Contents

System Attack Surface Analysis using Windows Attack Surface Analyzer 4

Download Attack Surface Analyzer 5

Download the Windows Binary Directly 5

Download the .NET Desktop Runtime 9.0 (x64) or the full .NET Runtime 9.0 (x64). 7

Install frameworks for dotnet 7

Launch the ASA Web Interface 8

Perform Baseline Scan (BaseScan1) 9

Intentionally Expand the Attack Surface (Open Port 21) 11

Verify port 21 is actually open 14

Analyzing Web Application Attack Surface using OWASP Attack Surface Detector (ZAP Plugin) 17

Launch OWASP ZAP 19

Install the Attack Surface Detector Add-on 19

Configure and Import Source Code 21

Review Attack Surface Results 22

System Attack Surface Analysis using Windows Attack Surface Analyzer

Learn to identify and analyze the Windows attack surface using Microsoft Attack Surface Analyzer (ASA) by taking baseline and post-change snapshots (focusing on open ports) and comparing them to detect unauthorized changes.

Objective:

Install and run Attack Surface Analyzer GUI

Perform a baseline static scan (ports only)

Intentionally expand the attack surface by enabling FTP (port 21)

Perform a product/post-change scan

Compare scans to detect the new open port and understand how defenders reduce attack surface

Machines Required

Machine	IP Address	Role
Windows 10	192.168.100.129	Target system for scanning

Tools Required

Tool	Purpose
Microsoft Attack Surface Analyzer (GUI, latest or v2.x)	Capture system snapshots (files, ports, users, registry, services, certificates) and compare changes
Web browser (Chrome/Edge)	Access the ASA web UI at http://localhost:5000
Windows Features / IIS Manager	Enable FTP Server to open port 21 for the demo

Download Attack Surface Analyzer

Go to the official Microsoft GitHub repository (search "Microsoft Attack Surface Analyzer") → Releases → Download the Windows GUI slim package (e.g., AsaGui-slim-win10-*.zip or current equivalent). Extract it to a folder on your Desktop.

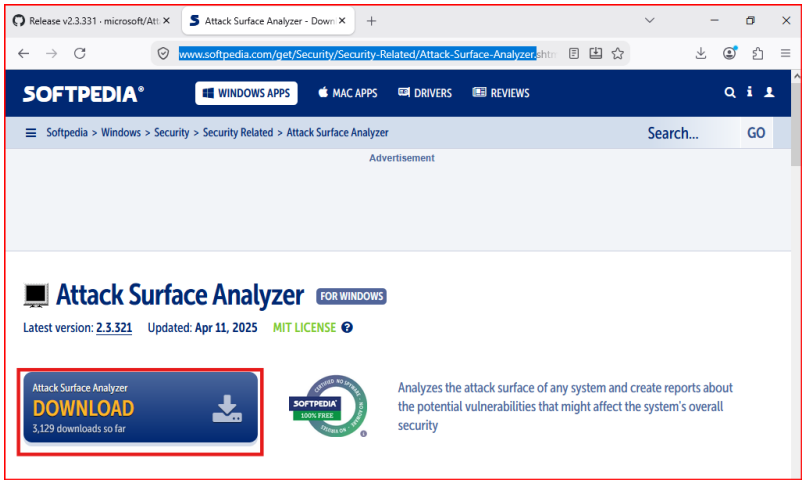
Prepare the Environment

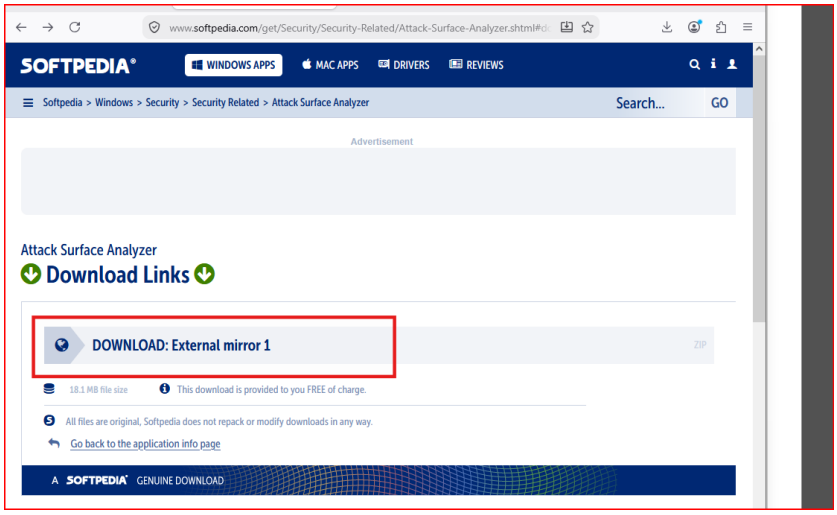
1. Log in to your Windows machine as an administrator.

Download the Windows Binary Directly

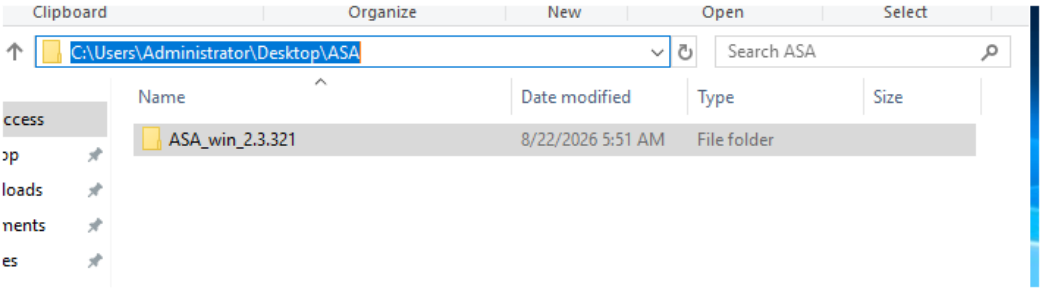
1. Open this link in your browser:
2. Softpedia has a ready Windows package (version 2.3.321):

https://www.softpedia.com/get/Security/Security-Related/Attack-Surface-Analyzer.shtml





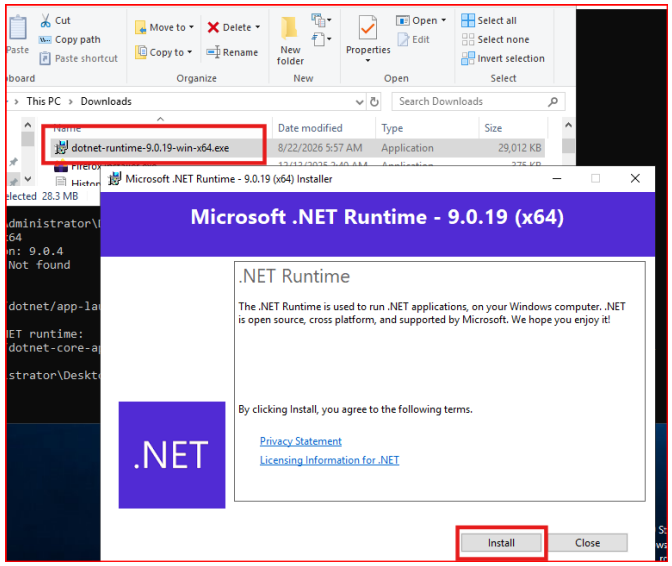
3. Scroll down to the **Assets** section.
4. Download the Windows version (look for a file similar to):
    - Asa-win-x64.zip
    - or AttackSurfaceAnalyzer-win-x64.zip
    - or any .zip that mentions **win** / **windows** / **x64**
5. Extract the downloaded .zip file to a folder on your Desktop.



Download the .NET Desktop Runtime 9.0 (x64) or the full .NET Runtime 9.0 (x64).

```
https://aka.ms/dotnet-core-applaunch?missing_runtime=true&arch=x64&rid=win-x64&os=win10&apphost_version=9.0.4
```

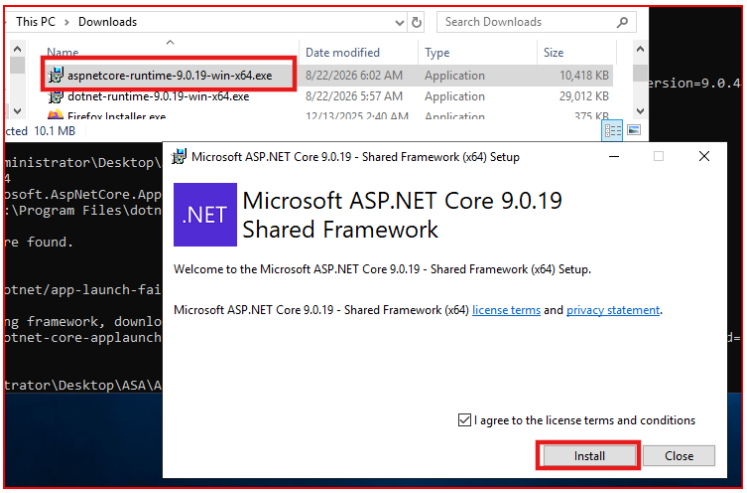
6. Install it (just click Next → Install).



Install frameworks for dotnet

Open this direct link:

```
https://aka.ms/dotnet-core-applaunch?framework=Microsoft.AspNetCore.App&framework_version=9.0.0&arch=x64&rid=win-x64&os=win10
```

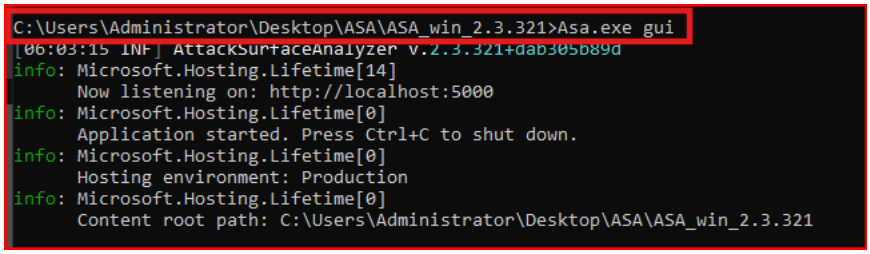


7. Open **Command Prompt as Administrator**:
8. Go to the extracted folder:

cd Desktop\ASA

(Adjust the path if you extracted it somewhere else)

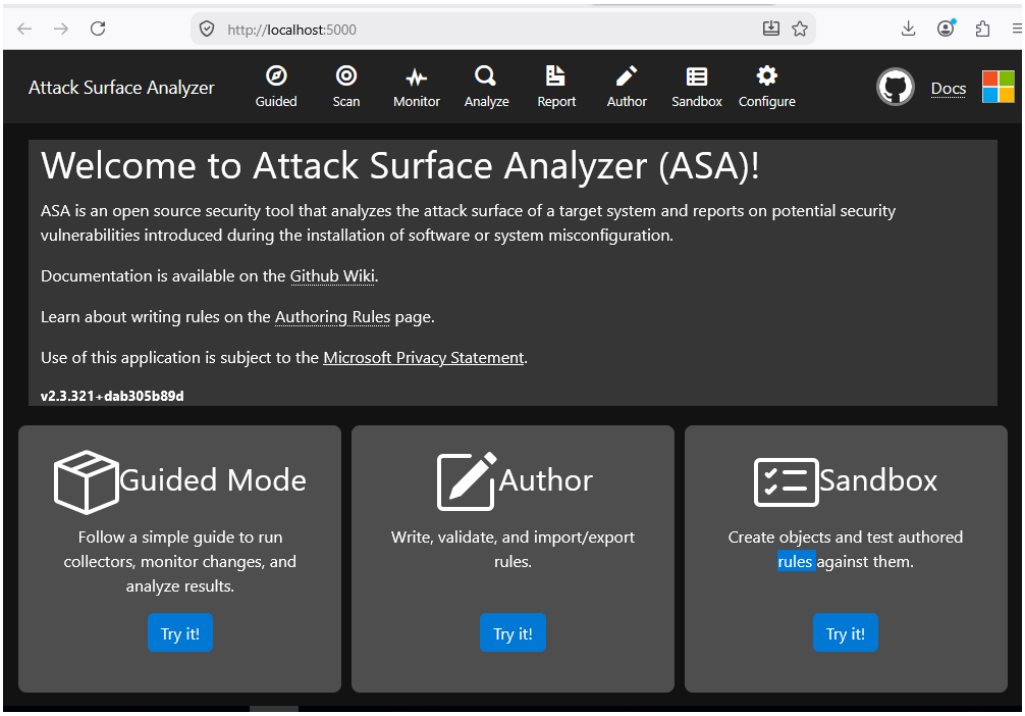
9. Run the GUI: `Asa.exe gui or asa.exe gui`



A browser window should open automatically at **http://localhost:5000**.

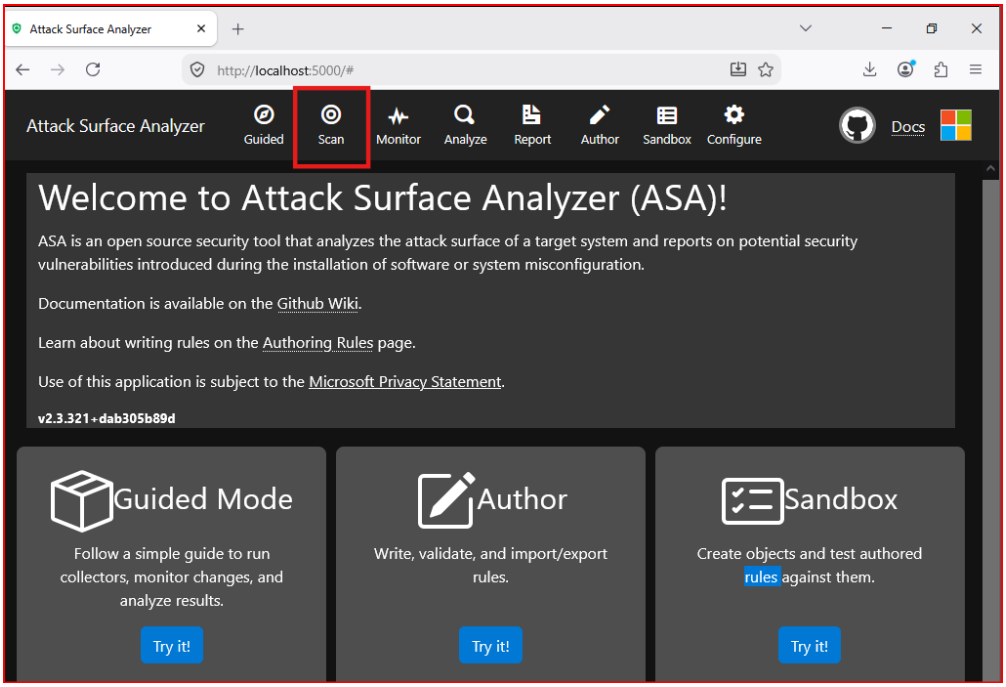
Launch the ASA Web Interface

1. Open Google Chrome or Edge.
2. Navigate to http://localhost:5000.



Perform Baseline Scan (BaseScan1)

Select Scan:



Do the following on the page you currently have opened:

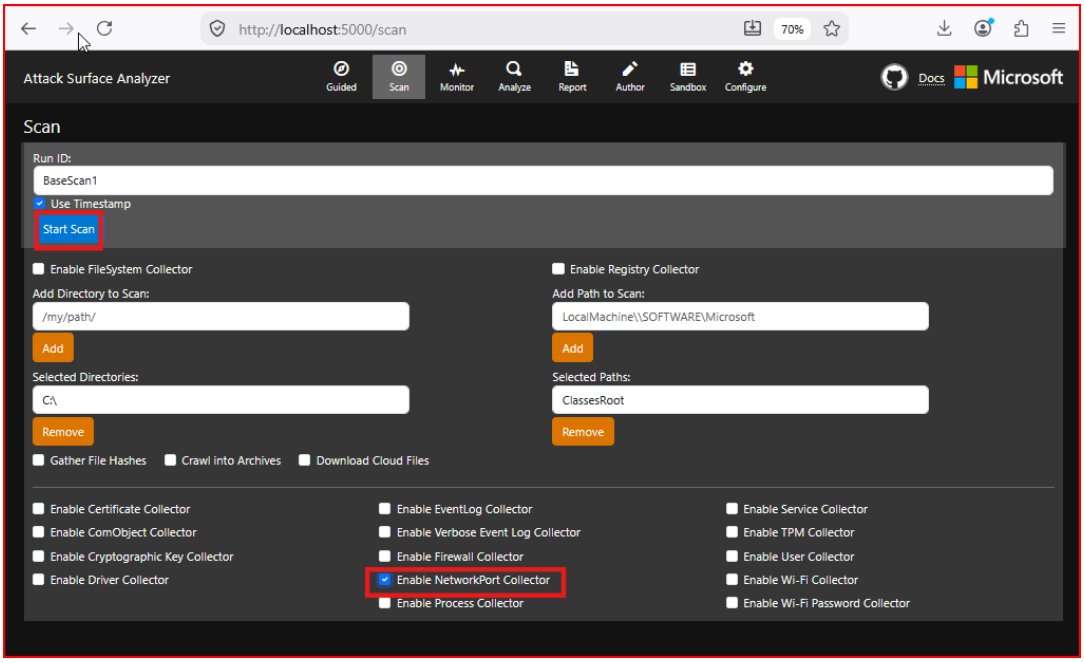
1. In the **Run ID** field, type:

BaseScan1

2. Make sure **Use Timestamp** is checked (it already is).
3. **Important – Collectors**:
    - Uncheck **everything**.
    - Only check this one box:
        - ✅ **Enable NetworkPort Collector**

(Leave FileSystem, Registry, Certificate, Service, User, etc. all unchecked)

4. Click the blue **Start Scan** button.

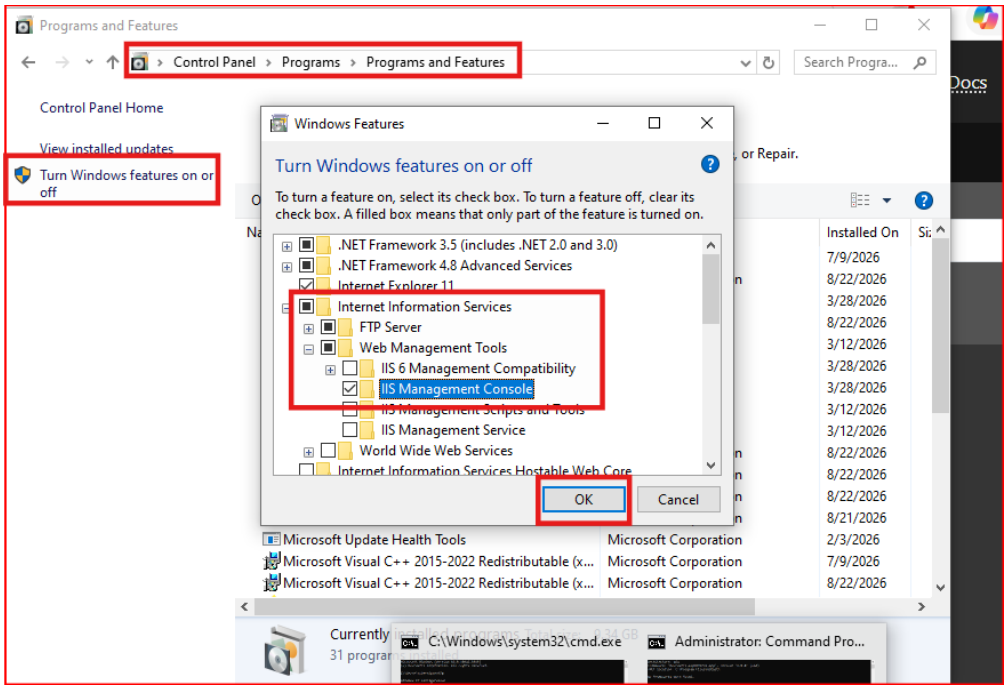


5. Wait until the scan finishes (you will see progress or a completion message).

Sometimes we don't see results (Perform next steps)

Intentionally Expand the Attack Surface (Open Port 21)

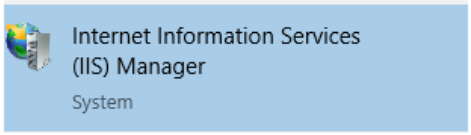
1. Open **Control Panel → Programs → Turn Windows features on or off**.
2. Expand **Internet Information Services**.
3. Check **FTP Server** (and all its sub-items) and **Web Management Tools → IIS Management Console**.



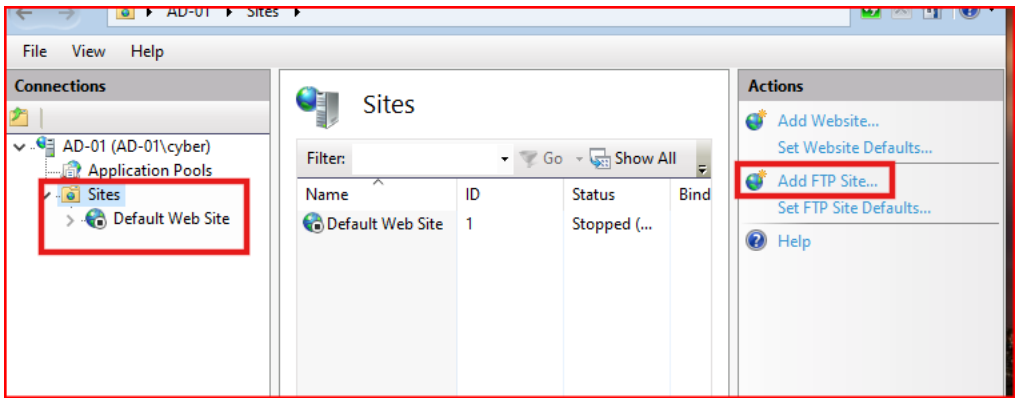
4. Click **OK** and restart the machine if prompted (or restart manually).
5. After reboot, create an empty folder (e.g., C:\DemoFtp or E:\DemoFtp).



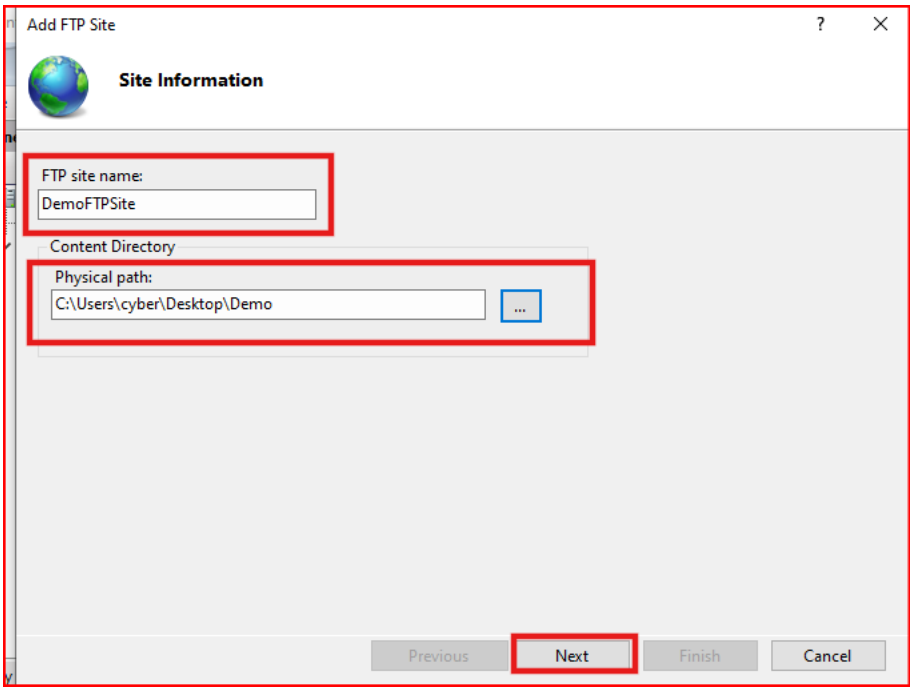
6. Search for and open **Internet Information Services (IIS) Manager**.



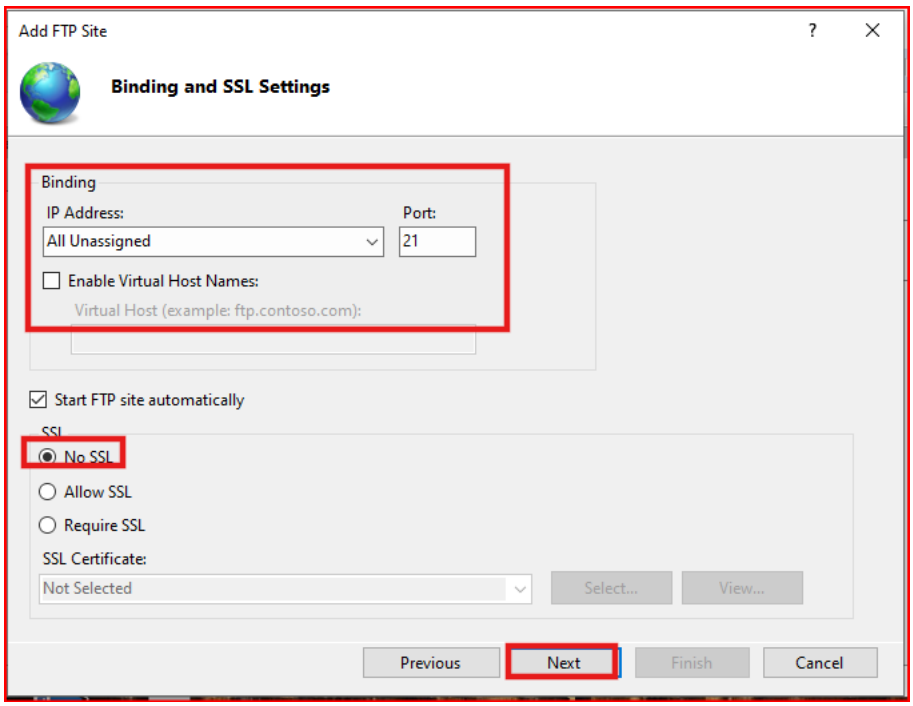
7. In the Connections pane, expand your server → right-click **Sites** → **Add FTP Site…**.



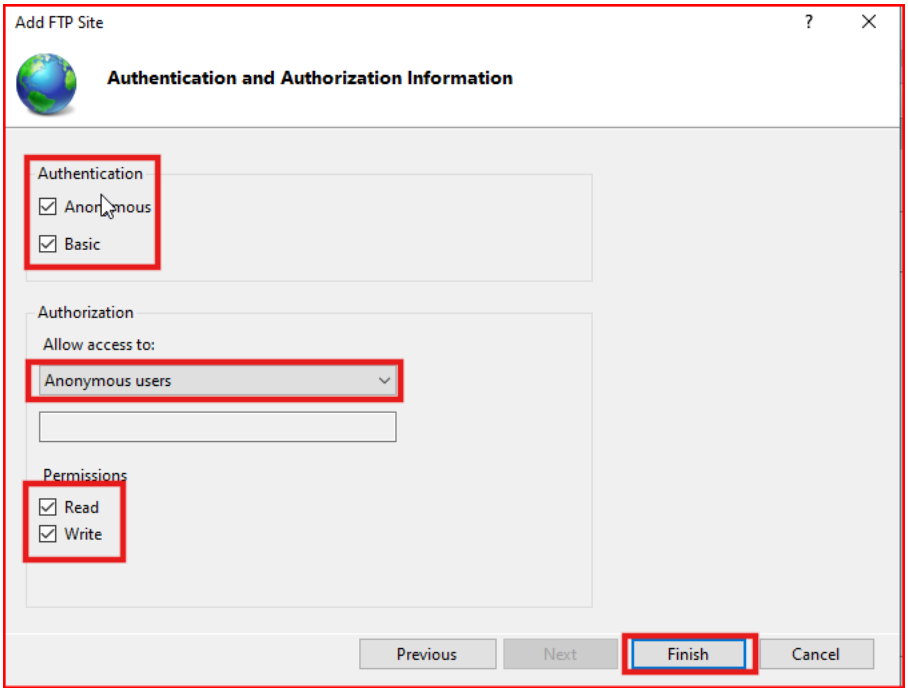
8. Site name: DemoFtpSite. Physical path: the folder you created. Click **Next**.



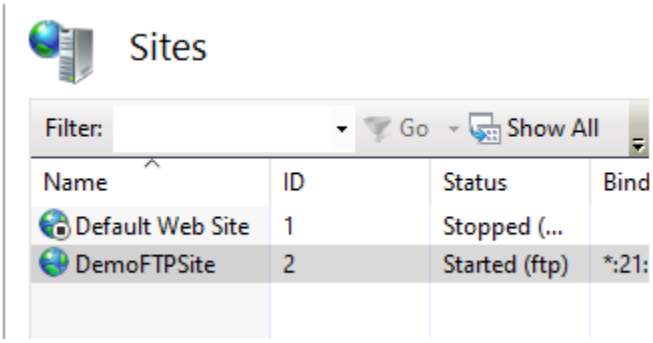
9. IP Address: select your host IP (or All Unassigned). Port: **21**. Select **No SSL**. Click **Next**.



10. Authentication: check both **Anonymous** and **Basic**. Authorization: **Anonymous users**. Permissions: check **Read** and **Write**. Click **Finish**.



11. Confirm the site is started. Close IIS Manager.



Verify port 21 is actually open

Open a new **Administrator Command Prompt** and run:

netstat -ano | findstr :21

```
C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321>
C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321>netstat -ano | findstr :21
  TCP    0.0.0.0:21             0.0.0.0:0              LISTENING       2308
  TCP    [::]:21                [::]:0                 LISTENING       2308
```

You should see a line with TCP 0.0.0.0:21 or TCP [::]:21 in **LISTENING** state. If you see it → the attack surface **has** increased (this is the key learning of the lab).

Step 2 – Force a clean comparison using CLI

1. Close the current ASA console window completely.
2. Open a **new Administrator Command Prompt**.
3. Run a brand-new baseline scan (only ports):

Asa.exe collect --network-port --runid CleanBase

```
C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321>Asa.exe collect --network-port --runid Clean
[20:46:08 INF] AttackSurfaceAnalyzer v.2.3.321+dab305b89d
[20:46:08 INF] Begin Clean.
[20:46:08 INF] Starting 1 Collectors.
[20:46:08 INF] Starting OpenPortCollector.
[20:46:09 INF] Completed OpenPortCollector in 00h:00m:00s:209ms.
```

4. After it finishes, run the second scan:

Asa.exe collect --enable-network-port --runid AfterFTP

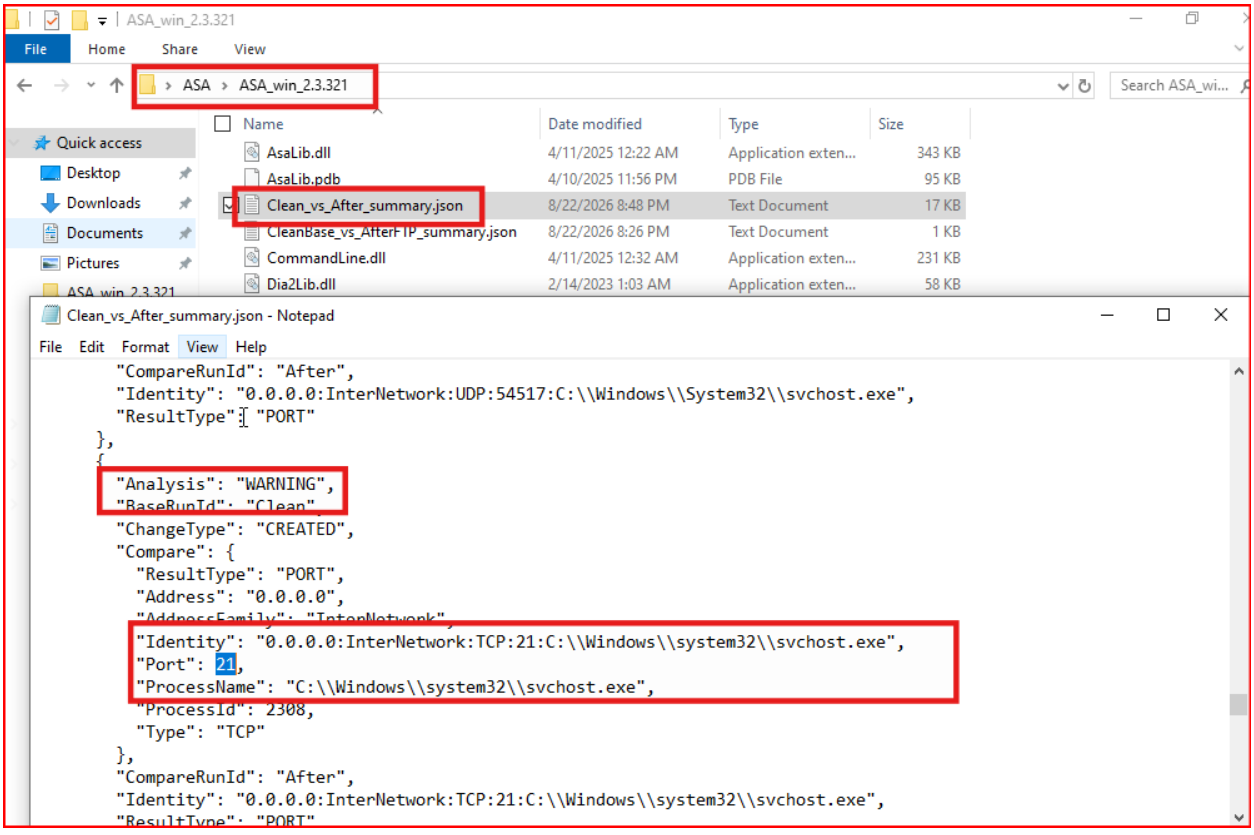
```
C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321>Asa.exe collect --network-port --runid After
[20:47:38 INF] AttackSurfaceAnalyzer v.2.3.321+dab305b89d
[20:47:38 INF] Begin After.
[20:47:38 INF] Starting 1 Collectors.
[20:47:38 INF] Starting OpenPortCollector.
[20:47:39 INF] Completed OpenPortCollector in 00h:00m:00s:217ms.
```

5. Now compare them:

Asa.exe export-collect --firstrunid CleanBase --secondrunid AfterFTP

```
C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321>Asa.exe export-collect --firstrunid Clean --secondrunid After
[20:48:22 INF] AttackSurfaceAnalyzer v.2.3.321+dab305b89d
[20:48:23 INF] Comparing Clean vs After.
[20:48:23 INF] Completed Comparing in 00h:00m:00s:101ms.
[20:48:29 INF] Completed Analysis in 00h:00m:05s:740ms.
[20:48:29 INF] Output written to: C:\Users\cyber\Desktop\ASA\ASA_win_2.3.321\Clean_vs_After_summary.json.txt
```

A JSON file will be created. Open it and search for 21 — you will see the port listed as Created.



Even if the GUI is stubborn, you have successful:

- Taken a baseline of open ports
- Opened an insecure service (FTP on port 21)
- Confirmed the change with netstat
- Understood how Attack Surface Analyzer is used by defenders to detect unauthorized increases in attack surface

Conclusion

You successfully used Microsoft Attack Surface Analyzer to capture a clean baseline of open ports, intentionally opened the insecure FTP port 21, re-scanned, and compared the results. The comparison clearly highlighted the newly created attack surface (port 21), demonstrating how defenders detect unauthorized changes and reduce risk by closing unnecessary services/ports.

Analyzing Web Application Attack Surface using OWASP Attack Surface Detector (ZAP Plugin)

Learn how to identify the attack surface of a web application by performing static code analysis with the OWASP Attack Surface Detector (ASD) plugin inside OWASP ZAP. Map endpoints, parameters, and HTTP methods from source code without needing a running application.

Objective:

- Install and launch OWASP ZAP
- Manually install the Attack Surface Detector add-on
- Import a sample web application source code (LuxuryTreats)
- Generate and view detected endpoints with parameters and HTTP methods
- Understand how static analysis reveals potential attack vectors for defenders

Machines Required

Machine	IP Address	Role
Windows 10/11 machine	192.168.100.145	Analysis workstation (Admin Machine-1 equivalent)

Tools Required

Tool	Purpose
OWASP ZAP (Zed Attack Proxy)	Web application security testing platform and host for the plugin
Attack Surface Detector add-on (.zap file)	Static code analysis plugin that extracts endpoints and parameters from source
Sample source code (LuxuryTreats.zip)	Target web application source for analysis
Web browser	Optional – for general use

Download notes (real-environment alternatives):

- **OWASP ZAP: Download the latest stable release from** https://www.zaproxy.org/download/
- **Attack Surface Detector:**

https://github.com/zaproxy/zap-extensions/releases/download/2.7/attacksurfacedetector-alpha-1.1.4.zap

Simple ASP.NET or similar web app source zip can be used for practice (or recreate a minimal one). The original lab file is a sample e-commerce style ASP.NET application.

https://github.com/TelerikAcademy/ASP.NET-Web-Forms/archive/refs/heads/master.zip

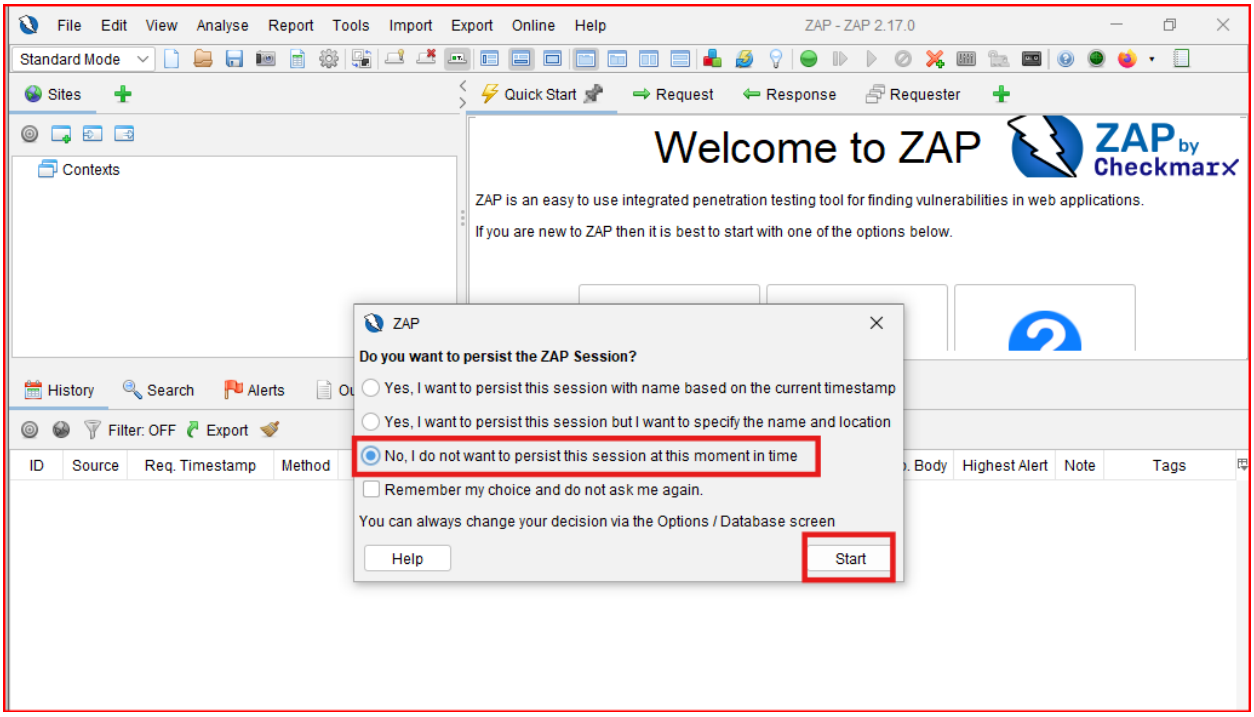
Prepare the Environment

1. Download and install the latest OWASP ZAP on your Windows machine.
2. Obtain the Attack Surface Detector add-on file (.zap) and place it on the Desktop.
3. Obtain or prepare a sample web application source code archive (e.g., LuxuryTreats.zip) and place it on the Desktop.
4. Log in to the Windows machine with an administrator account.



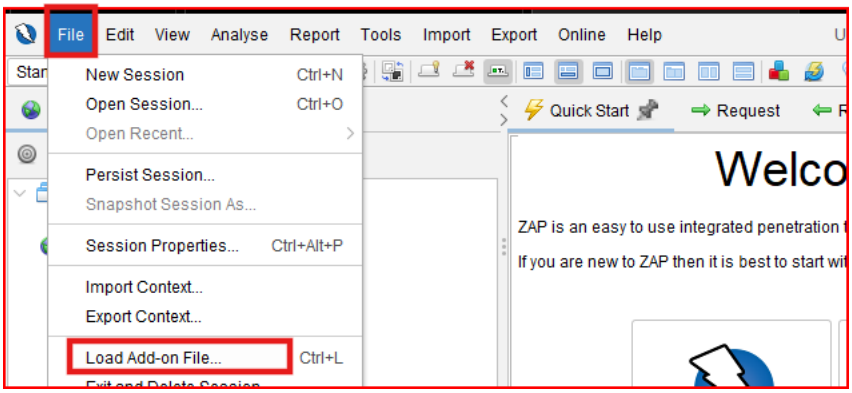
Launch OWASP ZAP

1. Double-click the OWASP ZAP shortcut (or launch from Start menu).
2. When the "Do you want to persist the ZAP Session?" dialog appears, select **No, I do not want to persist this session at this moment in time**.
3. Click **Start**.

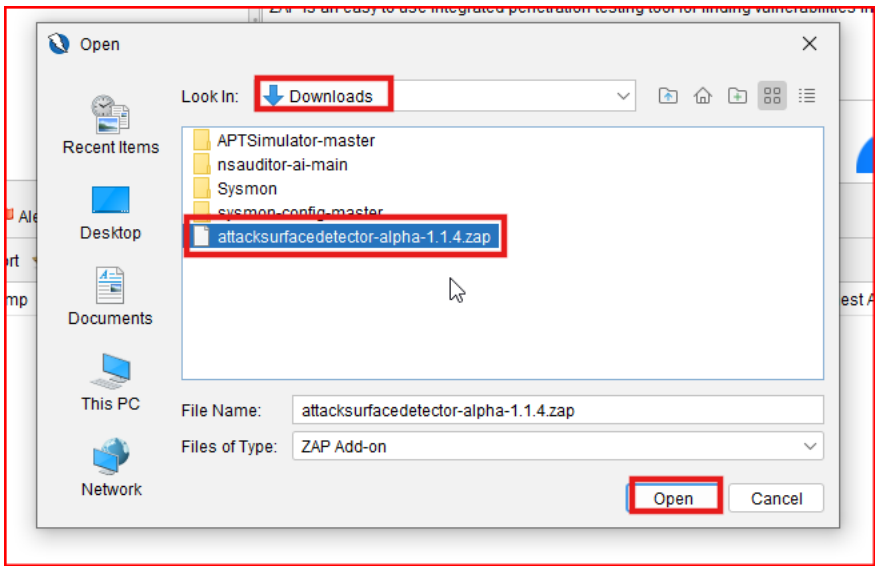


Install the Attack Surface Detector Add-on

1. In ZAP, go to **File → Load Add-on File…**.



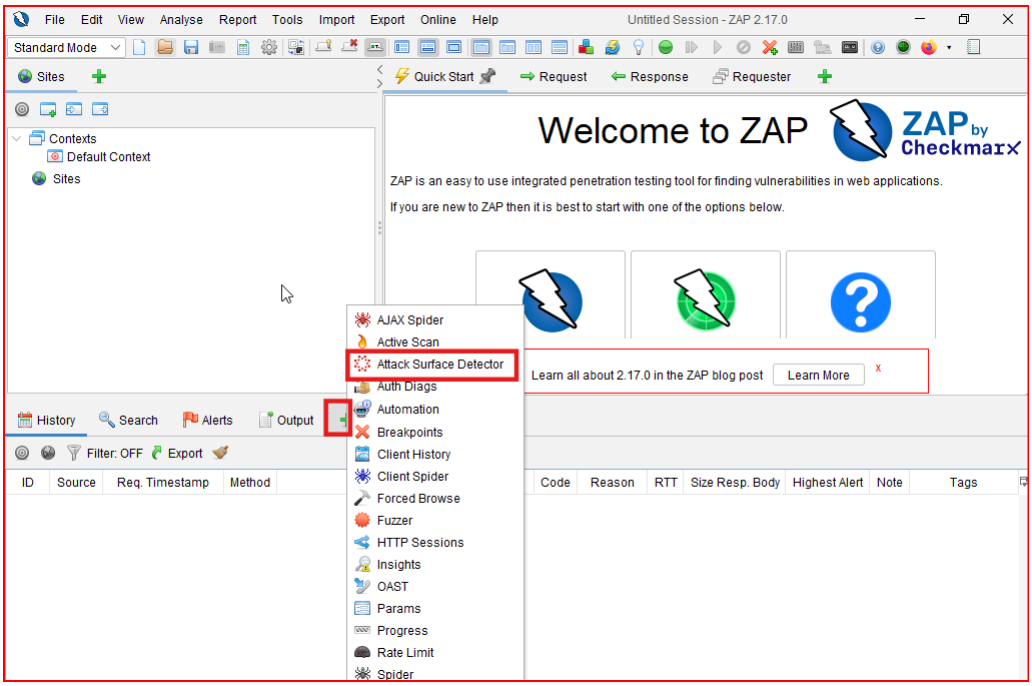
2. In the Open dialog, navigate to the Desktop, select the attacksurfacedetector-….zap file, and click **Open**.



3. Wait for the manual installation to be completed.

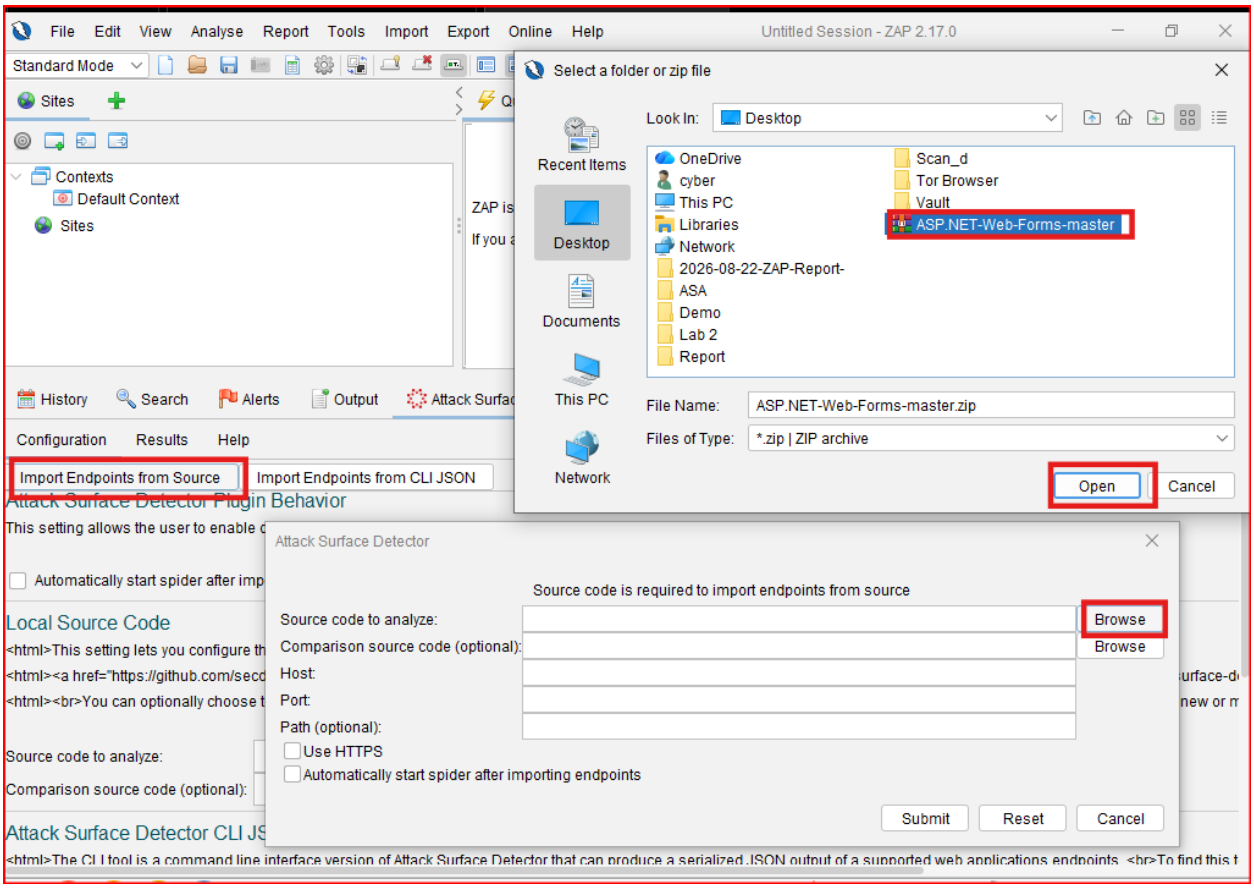
4. In the bottom pane, click the green **+** icon.

5. From the drop-down menu, select **Attack Surface Detector**. → A new **Attack Surface Detector** tab appears.



Configure and Import Source Code

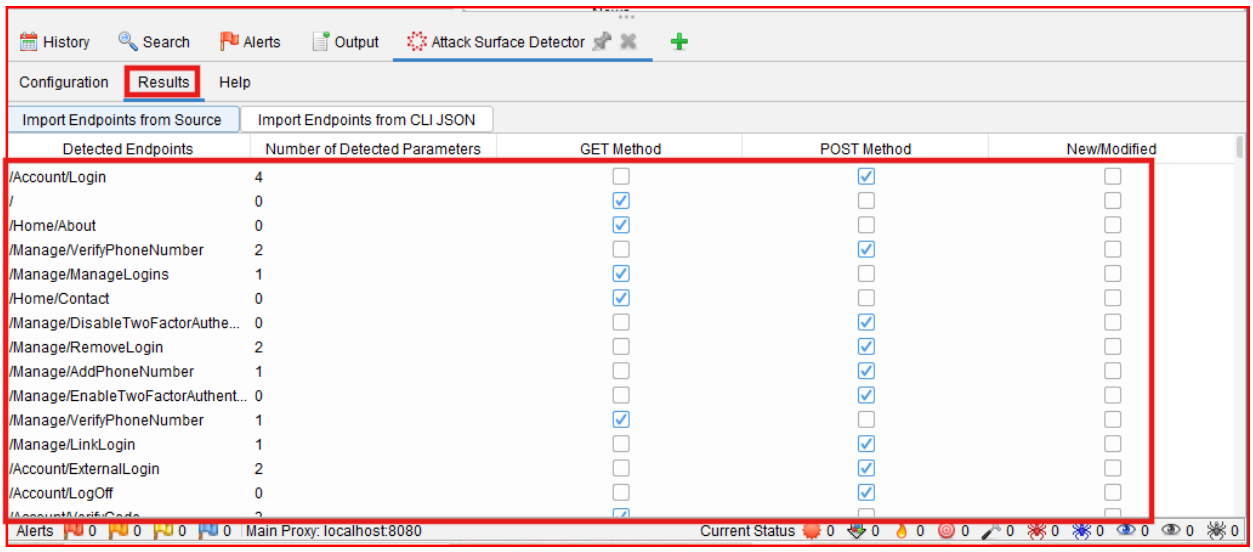
1. Click the **Attack Surface Detector** tab, then select the **Configuration** sub-tab.
2. Click **Import Endpoints from Source**.
3. In the dialog, click **Browse** (or the equivalent button).
4. Select the LuxuryTreats.zip (or your sample source) from the Desktop and click **Open**.
5. Click **Submit**.



6. Wait while the tool analyzes the source code.
7. When the message "The endpoints were successfully generated from source." appears, click **OK**.

Review Attack Surface Results

1. Click the **Results** tab inside the Attack Surface Detector pane.
2. Examine the list of **Detected Endpoints**.
3. Note the columns showing:
    - Number of Detected Parameters
    - GET Method support
    - POST Method support
    - Other relevant flags
4. Observe endpoints such as FAQ.aspx, Index.aspx, AboutUs.aspx, Download.aspx, AdminUpdateOrder.aspx, etc., and which ones accept parameters via GET (or POST).
5. This map represents the application's attack surface derived purely from static analysis of the source code.



Successfully installed the OWASP Attack Surface Detector plugin in ZAP, imported a web application's source code, and generated a clear map of its endpoints, parameters, and supported HTTP methods. This static analysis technique allows network defenders to identify potential attack vectors early—before the application is even deployed or running.

Conclusion

From the first baseline scan to the final web application map, Module 19 made the attack surface visible and measurable.

Microsoft Attack Surface Analyzer captured a clean system state, the intentional opening of port 21 was detected with precision, and the comparison proved how easily the surface expands. OWASP ZAP's Attack Surface Detector then inventoried every application entry point, giving a complete view of web-facing risk.

The lab is complete. Hidden doors have been found, changes have been quantified, and the path to shrinking the surface of the attack is now clear. Defenders see what attackers see — and can close the doors first.